

Information Security Management System (ISMS)

Scope Statement

ISMS Governance Policy | Version 1.0 | Approved

Document Owner	Information Security / GRC
Status	Approved 2026-09-23
Review Frequency	At least annually and upon significant change
Framework Alignment	ISO/IEC 27001:2022
Classification	Internal Use

1. Purpose

This document defines the scope of the Information Security Management System (ISMS) for Axiom AI Technologies.

The purpose of the ISMS is to establish a structured and risk-based approach to protecting the confidentiality, integrity, and availability of information assets supporting Axiom AI's business operations and cloud-based artificial intelligence services.

The ISMS provides the framework through which Axiom AI identifies information security risks, implements appropriate controls, evaluates control effectiveness, manages security-related responsibilities, and continually improves its information security program.

2. Organization Overview

Axiom AI Technologies is a fictional technology organization providing business-to-business cloud-based artificial intelligence and machine learning services.

The organization operates a cloud-first technology environment using Amazon Web Services (AWS) and supports a remote/hybrid workforce.

The organization's information environment includes sensitive business and technical information such as:

- Customer information
- Customer data processed through the platform
- Application and source code

- Artificial intelligence and machine learning models
- API credentials and authentication information
- Security and operational information
- Business and financial information
- Third-party service information
- Information required to operate and support the company's SaaS platform

3. ISMS Scope

The Axiom AI Technologies ISMS covers the people, processes, information, technology, and supporting services used to develop, operate, maintain, secure, and support the organization's B2B cloud-based AI/ML SaaS platform.

The scope includes:

3.1 Information Assets

The ISMS includes information assets that support or affect the security of Axiom AI's operations, including:

- Customer information
- Customer data
- Source code
- AI/ML models
- Application configuration
- Authentication credentials and secrets
- Security logs and monitoring information
- Vulnerability and security assessment information
- Risk and compliance records
- Business continuity information
- Vendor and third-party security information
- Internal business information

3.2 Technology Environment

The scope includes technology used to support the organization's information processing and SaaS operations, including:

- AWS cloud infrastructure
- Production and supporting cloud services
- Application environments
- Databases
- Storage services
- Identity and access management systems
- Logging and monitoring capabilities
- Security tooling

- Corporate endpoints
- Network and communication technologies
- Collaboration and productivity platforms

3.3 People and Roles

The ISMS applies to personnel whose responsibilities may affect information security, including:

- Executive management
- Engineering personnel
- Information security and GRC personnel
- IT and technical personnel
- Product personnel
- Operations personnel
- Contractors
- Relevant third-party service providers

3.4 Processes

The scope includes information security processes supporting:

- Risk management
- Security governance
- Access management
- Asset management
- Vulnerability management
- Incident response
- Business continuity and disaster recovery
- Third-party risk management
- Security monitoring
- Security assessment
- Compliance management
- Security awareness
- Change management
- Security remediation
- Internal review and continual improvement

4. Physical and Organizational Boundaries

Axiom AI operates using a remote/hybrid business model and cloud-based technology infrastructure.

The ISMS therefore considers information security risks associated with:

- Remote working
- Corporate endpoints

- Cloud infrastructure
- Third-party service providers
- Internet-facing applications and services
- Identity and access management
- Information exchanged between internal and external parties

Physical data-center infrastructure operated by cloud service providers is not directly owned or managed by Axiom AI. However, relevant cloud-provider security responsibilities, contractual requirements, and shared-responsibility considerations are included within the organization's information security risk management activities.

5. Interested Parties

The ISMS considers the information security requirements and expectations of relevant interested parties, including:

- Customers
- Employees
- Contractors
- Executive management
- Investors and business stakeholders
- Cloud service providers
- Technology vendors
- Other third-party service providers
- Regulators and applicable authorities
- Business partners

Relevant requirements may include contractual, legal, regulatory, customer, operational, and information security requirements.

6. Applicable Security Requirements

The ISMS is designed with consideration for applicable information security requirements and recognized security frameworks, including:

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST Cybersecurity Framework (CSF) 2.0
- NIST SP 800-53
- Applicable contractual and customer security requirements
- Applicable legal and regulatory requirements

The organization will periodically review applicable requirements and update the ISMS where changes may affect information security obligations.

7. ISMS Interfaces and Dependencies

The ISMS has dependencies and interfaces with internal and external parties.

Key dependencies include:

- AWS and other cloud service providers
- SaaS and technology vendors
- Identity and authentication services
- Security monitoring and logging services
- Communication and collaboration platforms
- Software development and deployment processes
- Customer-facing applications and APIs
- Third-party service providers

Security responsibilities associated with these dependencies are managed through risk assessment, contractual requirements, third-party security assessments, access controls, monitoring, and other applicable security controls.

8. Scope Exclusions

The following activities are outside the direct operational scope of the Axiom AI ISMS:

8.1 Direct Cloud Provider Infrastructure Management

Physical infrastructure operated by AWS or other cloud providers is outside Axiom AI's direct operational control.

However, security responsibilities applicable to Axiom AI under the cloud provider's shared-responsibility model remain within the ISMS.

8.2 Third-Party Internal Operations

Internal systems, personnel, and operational processes belonging solely to external service providers are outside the direct organizational scope of the ISMS.

Security risks arising from those providers remain within the scope of Axiom AI's third-party risk management activities.

8.3 Direct Production Security Testing

This assessment and portfolio exercise does not include live penetration testing, exploitation of production systems, vulnerability scanning of real infrastructure, malware execution against production systems, or other intrusive testing activities.

Such activities would require separate authorization and controlled testing procedures.

8.4 Real Customer or Production Data

This portfolio implementation uses fictional organizational information and does not contain real customer information, production secrets, credentials, contracts, or confidential organizational data.

9. Relationship to Risk Management

The ISMS scope is informed by Axiom AI's enterprise cyber risk assessment and supporting asset inventory.

Risks identified through the organization's risk management process are evaluated based on their potential impact to information confidentiality, integrity, and availability.

Risk treatment decisions are used to determine appropriate security controls and supporting policies.

The ISMS therefore operates as an integrated management system connecting:

Assets → Risks → Risk Treatment → Controls → Policies → Monitoring → Continual Improvement

10. Relationship to Security Controls

Security controls within the ISMS are evaluated against applicable requirements from ISO/IEC 27001:2022 and supporting security frameworks.

Axiom AI's control assessment evaluates the implementation and effectiveness of selected security controls and identifies areas requiring remediation or further validation.

The Statement of Applicability provides the formal record of applicable ISO/IEC 27001:2022 Annex A controls and their implementation status.

11. Continual Improvement

The ISMS will be maintained and continually improved through activities including:

- Periodic risk assessments
- Control effectiveness assessments
- Internal reviews

- Management reviews
- Security incident analysis
- Vulnerability management
- Corrective actions
- Remediation tracking
- Third-party security reviews
- Business continuity exercises
- Changes to legal, regulatory, contractual, or customer requirements
- Changes to the organization's technology environment

Findings and improvement opportunities will be tracked through the organization's risk, remediation, and governance processes.

12. Scope Statement

Based on the organizational, technological, informational, and process boundaries described above:

The Axiom AI Technologies Information Security Management System applies to the people, processes, information, technology, and supporting services used to develop, operate, maintain, secure, and support Axiom AI's cloud-based B2B artificial intelligence and machine learning SaaS platform, including associated corporate, cloud, security, business continuity, and third-party risk management activities.

The ISMS scope considers relevant internal and external issues, interested parties, information security risks, contractual and regulatory requirements, organizational dependencies, and the organization's operating environment.

13. Document Review

This document shall be reviewed periodically and whenever significant changes occur to:

- Organizational structure
- Business operations
- Technology architecture
- Information processing activities
- Cloud infrastructure
- Regulatory or contractual requirements
- Security risks
- Third-party dependencies
- ISMS boundaries

Changes to the ISMS scope shall be documented, reviewed, and approved through the organization's information security governance process.